QUESTION 10: HANDLING FALSE POSITIVE ALERTS

DG Interns Hub Cybersecurity Internship – Week 5 Submission

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** False Positive Verification & Detection Rule Tuning

1. THE L1 ANALYST ROLE IN FALSE POSITIVE TRIAGE

In a Security Operations Center, **False Positives (FPs)** represent benign activities that trigger security rules due to misconfigurations, broad rule parameters, or routine system maintenance. As the primary filter in the SOC, the L1 analyst is responsible for identifying false positives, verifying their legitimacy, documenting investigation steps, and flagging noisy rules for detection engineering updates.

2. VERIFICATION PROTOCOL: CONFIRMING A FALSE POSITIVE

An analyst must never assume an alert is false based on intuition. A rigorous verification protocol requires:

User/Admin Context Verification: Reach out to the user or system administrator to confirm if the activity was part of authorized work (e.g., scheduled software deployment, vulnerability testing). **Cross-Log Analysis:** Check SIEM/EDR logs before and after the event to confirm no secondary malicious actions took place (e.g., no command-and-control traffic or persistence creation). **Threat Intelligence Checks:** Verify hashes, domain names, and external IPs against VirusTotal and AbuseIPDB to rule out external malicious association. **Historical Baseline Check:** Determine if the targeted server or user account routinely performs this administrative task as part of normal operations.

3. DETECTION RULE TUNING PROCESS & PRACTICAL EXAMPLES

To prevent analysts from triaging the exact same benign event repeatedly, detection rules must be tuned using granular exclusions:

Triggering Alert	Investigation Finding	Recommended Detection Tuning Action
Internal Network Scanning	Alert triggered by internal host `10.0.5.20`. Investigation confirms it is the company's official Nessus Scanner.	Modify SIEM rule logic to exclude source IP: `WHERE src_ip != "10.0.5.20"`.
Unusual PowerShell Script	EDR flags custom backup script `backup_sync.ps1` executed daily by IT Operations.	Add binary hash or trusted file path signature exclusion: `C:\Program Files\ITOps\Scripts\`.
High Volume Failed SSH Logins	Monitoring service misconfigured with expired service account password.	Fix credentials on service account and add alert threshold delay (e.g., trigger only if count > 20 in 1 min).

4. THE GOLDEN RULE OF SOC TRIAGE

> **Golden Rule: Never Close an Alert Without Verification**
>
> An analyst must **NEVER** close an alert as a False Positive without carrying out proper verification steps and documenting clear proof. Attackers often intentionally mimic common administrative behavior (such as abusing built-in Windows commands like `net.exe` or `powershell.exe`) to blend in with legitimate traffic. Closing alerts without thorough checks creates critical blind spots, allowing real breaches to go unnoticed.

5. DOCUMENTING FALSE POSITIVES IN TICKET SYSTEMS

When closing a False Positive ticket, the analyst must provide clear details:

Closing Category: Closed - False Positive (Benign Administrative Activity). **Summary Note:** *"Alert verified with IT Admin (J. Smith). The PowerShell execution was an authorized routine maintenance script deployed via System Center Configuration Manager (SCCM). No malicious network connections or secondary payloads were detected. Closed ticket and submitted tuning request to SOC Engineering."*

6. TERMINOLOGY & REFERENCES

Detection Engineering: The SOC team dedicated to crafting, testing, and fine-tuning SIEM and EDR detection rules. **Whitelist / Exclusion List:** Approved list of IP addresses, file paths, or users excluded from triggering specific alerts.

References:

• Sigma Rule Tuning Guidelines: **https://github.com/SigmaHQ/sigma**
• NIST SP 800-61 Rev. 2 - Handling False Alarm Metrics: **https://csrc.nist.gov/**